Systemsicherheit: Übungsblatt 01

Raphael Bleier, Wintersemester 2026/27

Lösung

Quellenstand: 13.10.2026. Grundlage sind die aktuellen VO-Folien *Einleitung und Motivation*, insbesondere Folien 1-4 bis 1-8 und 1-18 bis 1-27, sowie das im Blatt verlinkte Microsoft-Learn-Modul zu Datenflussdiagrammen. KI-Unterstützung: Hermes Agent, Modell `gpt-6.1-sol` über `openai-codex`; Erstellung und getrennte Zweitprüfung am 13.10.2026. Ein genauer Agent-Build ist nicht verfügbar.

Aufgabe 1.1

Finden Sie aktuelle Informationsquellen zur IT-Sicherheit: allgemeine Veröffentlichungen, News-Dienste, wissenschaftliche Datenbanken, Ressourcen der Universitätsbibliothek und weitere interessante Seiten.

(a)

Das BSI veröffentlicht Lageberichte, Studien, Broschüren und Checklisten unter `https://www.bsi.bund.de/DE/Service-Navi/Publikationen/publikationen_node.html`. Diese Quellen passen für Grundlagen, Empfehlungen und eingeordnete Bedrohungslagen. Für eine konkrete neue Schwachstelle ist zusätzlich die aktuelle Herstellerwarnung nötig; ein älterer Lagebericht ersetzt keine aktuelle Versionsprüfung.

BSI-Publikationen für Grundlagen und Einordnung

(b)

heise security bietet Nachrichten, Warnungen und Hintergründe: `https://www.heise.de/security/`. CERT.at bündelt Warnungen und weitere Meldungen unter `https://cert.at/de/services/meldungen/`. Bei einem konkreten Vorfall prüfe ich Veröffentlichungsdatum, spätere Aktualisierungen und die verlinkte Primärquelle, weil eine frühe Meldung noch nicht alle betroffenen Versionen oder Gegenmaßnahmen enthalten muss.

heise security und CERT.at für laufende Meldungen

(c)

dblp erschließt wissenschaftliche Informatikpublikationen in Zeitschriften und Tagungsbänden: `https://dblp.org/`. Es ist ein bibliografischer Index, keine Garantie für freien Volltext oder die Qualität jedes einzelnen Beitrags. Über den Eintrag lässt sich die ursprüngliche Veröffentlichung finden. Als Volltextplattform ist außerdem IEEE Xplore relevant; die AAU nennt sie in ihren Zugriffsangeboten für elektronische Medien.

dblp für Nachweise; IEEE Xplore für Fachpublikationen

(d)

Die AAU bietet die Literatursuche *surf@ubk*, das Datenbank-Infosystem DBIS und Zugang zu elektronischen Medien an. Die offizielle Literatursuche und die DBIS-Seite sind: `https://www.aau.at/universitaetsbibliothek-klagenfurt/literatursuche/` und `https://www.aau.at/universit`

aetsbibliothek-klagenfurt/literatursuche/datenbanken/. Die Seite *Zugriff auf elektronische Medien* nennt unter anderem IEEE Xplore und Springer: https://www.aau.at/universitaetsbibliothek-klagenfurt/literatursuche/zugriff-auf-elektronische-medien/. Zugang und Lizenzumfang sind für das jeweilige Werk zu prüfen. Ein Suchtreffer bedeutet nicht automatisch freien Volltext.

surf@ubk, DBIS und lizenzierte elektronische Medien

(e)

OWASP stellt frei zugängliche Informationen zur Sicherheit von Webanwendungen bereit. Die Top-Ten-Projektseite ist https://owasp.org/www-project-top-ten/; sie nennt zum Prüfzeitpunkt die Ausgabe 2025 als aktuelle veröffentlichte Fassung. Microsoft Learn bietet das im Blatt vorgeschriebene Modul zu Threat Modeling mit Datenflussdiagrammen. Es erklärt Prozesse, Datenspeicher, externe Entitäten, Datenflüsse und Vertrauensgrenzen.

OWASP und Microsoft Learn als praktische Ergänzung

Aufgabe 1.2

Vergleichen Sie Vertraulichkeit, Integrität, Verfügbarkeit und Authentizität für Postkarte (Pk), Brief (B), Einschreiben (E), Einschreiben mit Rückschein (ER) und die jeweiligen elektronischen Varianten ePk, eB, eE, eER.

Die elektronischen Varianten sind hier funktionale Entsprechungen aus den VO-Folien, keine Behauptung über ein bestimmtes Produkt. Vertraulichkeit verhindert unberechtigten Informationsgewinn; Integrität betrifft unbemerkte unberechtigte Änderungen. Verfügbarkeit betrifft die Nutzbarkeit. Authentizität betrifft die Echtheit von Ursprung und Inhalt.

Anforderung	Pk	B	E	ER
Vertraulichkeit	Nein: Inhalt offen lesbar.	Teilweise: Umschlag erschwert Lesen, garantiert es nicht.	Wie Brief; Empfangsbestätigung schützt den Inhalt nicht zusätzlich.	Wie Brief; Rückschein schafft keine zusätzliche Geheimhaltung.
Integrität	Schwach: Inhalt ergänzbar; Änderungen können sichtbar sein.	Umschlag/Siegel können Öffnen anzeigen, sind aber überwindbar.	Zustellnachweis belegt nicht den unveränderten Inhalt.	Rückschein belegt nicht den unveränderten Inhalt.
Verfügbarkeit	Zustellung abhängig von Postbetrieb, Adresse und Verlust.	Gleiche Abhängigkeiten; keine garantierte Zustellung.	Dokumentierte Übergabe bzw. Zustellversuch; Verlust/Ausfall bleiben möglich.	Wie E; auch Übermittlung des Rückscheins kann ausfallen.
Authentizität	Absender frei eintragbar; Unterschrift nur Indiz.	Eigenhändige Unterschrift als überprüfbares Indiz; Umschlag allein genügt nicht.	Bestätigte Übergabe ersetzt keine Prüfung des Verfassers.	Rückschein stärkt Empfangsnachweis, nicht automatisch Verfasser- oder Inhaltsechtheit.

Anforderung	ePk	eB	eE	eER
Vertraulichkeit	Unverschlüsselte E-Mail: keine Ende-zu-Ende-Geheimhaltung.	Ende-zu-Ende-Verschlüsselung möglich; Metadaten bleiben ggf. sichtbar.	Inhalt kann verschlüsselt sein; vertrauenswürdiger Zustelldienst erforderlich.	Wie eE; Quittungen müssen selbst angemessen geschützt werden.
Integrität	Ohne geeigneten Schutz Inhalt/Absender veränderbar.	Authentifizierte Verschlüsselung oder Signatur erkennt unberechtigte Änderungen.	Signierter Zustellnachweis kann an den Inhalts-Hash gebunden werden.	Signierte, inhaltsgebundene Rückquittung ermöglicht zusätzliche Nachweisprüfung.
Verfügbarkeit	Abhängig von Netzen, Servern und Konten.	Zusätzlich Schlüsselzugang nötig; Verschlüsselung garantiert keine Erreichbarkeit.	Zustelldienst und sichere Ablage verbessern Nachvollziehbarkeit, nicht absolute Verfügbarkeit.	Wie eE; auch Rückquittung und deren Ablage müssen erreichbar sein.
Authentizität	From-Feld allein nicht vertrauenswürdig.	Digitale Signatur mit geprüfter Schlüssel-/Identitätsbindung.	Authentifizierte Parteien und signierte Nachweise eines vertrauenswürdigen Dienstes.	Zusätzlich überprüfbare Empfangsquittung, gebunden an Empfänger und konkreten Inhalt.

Eine automatische E-Mail-Lesebestätigung genügt nicht als kryptografisch gesicherter Rückschein. Ein Inhalts-Hash braucht einen authentischen Nachweis, weil ein Angreifer bei einer ungeschützten Nachricht auch einen neuen Hash mitschicken kann. Bei Signaturen bleiben Schlüsselvertrauen, Schlüsselkompromittierung und die rechtlichen Anforderungen an einen verbindlichen Nachweis zu berücksichtigen.

Empfangsnachweis ist kein vollständiger CIA+-Schutz

Aufgabe 1.3

(a) Nennen Sie andere Angriffsziele als Informationen. (b) Beschreiben Sie Unterbrechen, Ausschleusen, Modifizieren und Erzeugen anhand von Beispielen und ordnen Sie die Anforderungen aus CIA+ zu.

(a)

Angriffsziele sind auch Hardware, Software, Rechenzeit, Stromversorgung, Netzwerkzugang und die Betriebsfähigkeit eines Dienstes. Ein Angreifer kann Geräte zerstören, Rechenleistung für fremde Zwecke verwenden oder einen Dienst blockieren. Menschen, deren Vertrauen und die Reputation eines Betreibers können ebenfalls Ziele sein. Das Angriffsziel muss daher nicht eine gestohlene Datei sein.

Auch Infrastruktur, Ressourcen und Menschen sind Ziele

(b)

Unterbrechen: Ein Angreifer blockiert die Verbindung zwischen Quelle Q und Ziel Z oder überlastet den Empfänger. Das verletzt Verfügbarkeit. Redundante Wege, DDoS-Abwehr, Notfallabläufe und Kapazitätsplanung können die Auswirkungen begrenzen. Verschlüsselung verhindert das Unterbrechen nicht.

Ausschleusen: Ein Angreifer kopiert übertragene Bestelldaten, während die Übertragung weiterläuft. Das verletzt Vertraulichkeit. Geeignete Verschlüsselung und Zugriffsschutz wirken dagegen. Der Vorfall kann unbemerkt bleiben, weil die ursprüngliche Nachricht weiterhin ankommt.

Modifizieren: Ein Angreifer ändert in einer Zahlungsanweisung den Empfänger oder den Betrag. Das verletzt Integrität und kann zugleich Authentizität betreffen. MACs, digitale Signaturen oder authentifizierte Verschlüsselung ermöglichen die Erkennung unberechtigter Änderungen, wenn die Schlüssel und ihre Zuordnung geschützt sind.

Erzeugen: Ein Angreifer sendet eine erfundene Bestellung im Namen eines anderen Benutzers. Das verletzt insbesondere Authentizität. Authentifizierung, geprüfte Signaturen und Autorisierung wirken dagegen. Eine wiederholte alte gültige Nachricht erfordert zusätzlich Replay-Schutz, etwa eindeutig gebundene Transaktionsnummern.

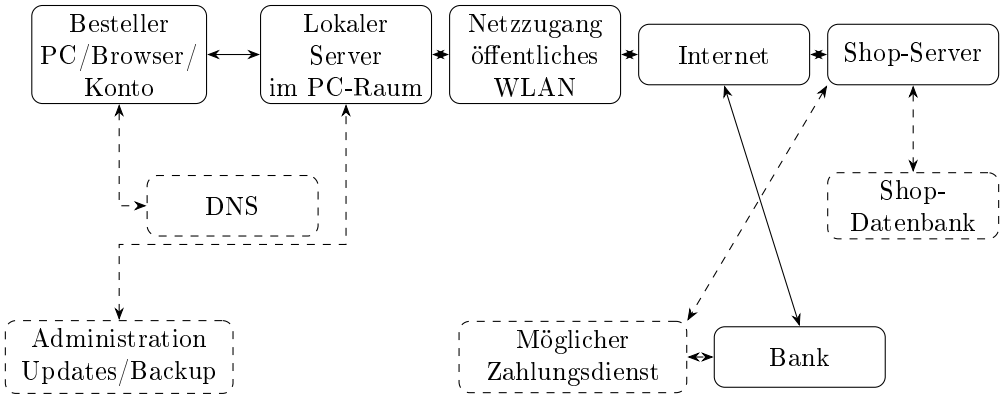
Unterbrechen: A; Ausschleusen: C; Ändern: I; Fälschen: Echtheit

Aufgabe 1.4

Betrachten Sie den öffentlichen PC-Raum mit Online-Bestellern, öffentlichem WLAN, Internet, Online-Shopping-Server und Bank. (a) Ergänzen Sie Komponenten. (b) Welche sind angreifbar? (c) Wie? (d) Wer sind mögliche Angreifer? (e) Welche Motive gibt es? (f) Welche Schutzmaßnahmen passen?

(a)

Die ergänzte Grafik enthält DNS, Shop-Datenbank, einen möglichen Zahlungsdienstleister und Administration. Der lokale Server im PC-Raum und die Internetanbindung der Bank aus der Ausgangsgrafik bleiben erhalten. Betriebssystem, Browser, Erweiterungen und lokale Konten gehören zu den Endgeräten. Der WLAN-Zugang und die lokale Infrastruktur bleiben eigene Angriffspunkte. Gestrichelte Komponenten und Verbindungen sind Ergänzungen mit angenommenen Beziehungen, keine bereits festgelegte Architektur. Die Pfeile zeigen Kommunikationsbeziehungen, nicht einen festgelegten zeitlichen Zahlungsablauf.



Endgeräte, Namensauflösung, Datenhaltung und Betrieb ergänzen

(b)

Alle dargestellten und ergänzten Komponenten können grundsätzlich angegriffen werden. Das gilt auch für Nutzer, Administratoren und Dienstleister, weil Menschen Zugangsdaten preisgeben oder unsichere Einstellungen übernehmen können. Die konkreten Bedrohungen unterscheiden sich nach Zugang, Berechtigungen und vorhandenen Schwachstellen.

Alle Komponenten prüfen, nicht nur den Shop-Server

(c)

Am öffentlichen PC sind manipulierte Browser, schädliche Erweiterungen, Keylogger oder verbliebene Sitzungen denkbar. Am lokalen Server können unberechtigte Zugriffe, unsichere Konfigurationen oder Überlastung den PC-Raum betreffen. Im WLAN sind ein falscher Access Point, Mitschneiden ungeschützter Daten und Störungen möglich. DNS-Manipulation kann zu einem falschen Ziel führen; eine korrekte HTTPS-Zertifikatsprüfung ist dabei ein eigener Schutzschritt. Beim Shop sind beispielsweise fehlende Zugriffskontrollen, injizierte Datenbankabfragen und Überlastung relevant. In Datenbank und Backups drohen unberechtigtes Lesen, Ändern oder Löschen. An Zahlungsdienst und Bank drohen Phishing, gefälschte Zahlungsaufträge oder kompromittierte Konten. Bei Administration und Updates sind gestohlene privilegierte Zugänge oder manipulierte Softwarelieferungen relevant.

Angriffe nach Endgerät, Netz, Anwendung und Betrieb ordnen

(d)

Mögliche Angreifer sind externe Kriminelle, Mitbenutzer des PC-Raums, böswillige Kunden, Mitarbeiter des Shops, Administratoren oder kompromittierte Dienstleister. Auch ein Betreiber kann Daten unberechtigt verwenden. Ein aktiver Angreifer ist von einer Person zu unterscheiden, die aus Versehen einen sicherheitsrelevanten Fehler macht.

Externe und berechtigte interne Personen berücksichtigen

(e)

Motive sind finanzieller Gewinn, Datendiebstahl, Identitätsmissbrauch, Erpressung, Sabotage, Rache, Wettbewerbsvorteile oder ein politisches Ziel. Neugier und der Wunsch nach Anerkennung können ebenfalls zu unberechtigten Angriffen führen. Diese Motive erklären das Handeln, erteilen aber keine Erlaubnis zum Angriff.

Motive reichen von Gewinn bis Sabotage und Anerkennung

(f)

Auf fremden öffentlichen PCs sollten sensible Bestellungen und Bankgeschäfte vermieden werden. Eigene Endgeräte brauchen Updates und kontrollierte Software. Sitzungen sind abzumelden; gespeicherte Zugangsdaten und Zahlungsinformationen gehören nicht auf öffentliche Geräte. HTTPS mit geprüften Zertifikaten schützt geeignete Transportverbindungen, nicht alle Endgerätrisiken. Shop und Datenbank brauchen Eingabevalidierung, parametrisierte Abfragen, Zugriffskontrollen und getrennte Berechtigungen. Der lokale Server braucht ebenfalls Updates, eingeschränkte Rechte, kontrollierte Konfiguration und Wiederherstellungsmöglichkeiten. Administrative Konten sollten mit Mehrfaktor-Authentifizierung geschützt und vom normalen Betrieb getrennt werden. Backups, Wiederherstellungstests, DDoS-Vorsorge, Protokollierung, Schulungen und klare Meldewege ergänzen die technischen Maßnahmen. Beim Bezahlen sind Zahlungsempfänger und Betrag vor der Bestätigung zu prüfen.

Technik, Organisation und geschulte Personen gemeinsam schützen

Aufgabe 1.5

Nutzen Sie das verlinkte Microsoft-Modul: (a) Unterschied logisches/physisches DFD? (b) Beschreiben Sie das Telehealth-DFD des Blatts. (c) Wo sollten Trust Boundaries stehen und warum?

(a)

Ein logisches DFD beschreibt die fachlichen Vorgänge und die zwischen ihnen fließenden Daten, unabhängig von einer konkreten technischen Implementierung. Ein physisches DFD ergänzt die Umsetzung durch konkrete Geräte, Dienste, Speicher und Übertragungswege. Beispiel: "Messdaten übernehmen" ist eine logische Tätigkeit; eine App, ein Serverprozess und eine bestimmte Datenbank beschreiben deren technische Umsetzung. Beide Sichten nutzen externe Entitäten, Prozesse, Datenspeicher und gerichtete Datenflüsse.

Logisch: fachliche Aufgabe; physisch: technische Umsetzung

(b)

Das Blatt zeigt links den Patienten als externe Entität. Dieser sendet eine Login-Anfrage an das Prozess-Element *App on patient communication device* und erhält eine Login-Antwort. Die App tauscht Authentifizierungsanfragen und Ergebnisse mit dem als Speicher gezeichneten *Patient communication devices* aus.

Der Datenspeicher *Patient medical devices* liefert Messungen an diesen Speicher. Ein Prozess *Personal/Electronic health record Servers* empfängt Daten von den Kommunikationsgeräten und sendet Daten an diese zurück. Die beiden Pfeile heißen nur *Data*; konkrete Inhalte der Rückübertragung sind nicht angegeben. Der Prozess tauscht außerdem Daten mit der *Health Database* aus. Die Form des Elements ist hierbei wichtig: Im gegebenen DFD sind die medizinischen und die Kommunikationsgeräte mit dem Datenspeichersymbol gezeichnet, nicht als externe Personen.

Rechts stehen *Healthcare providers* als externe Entität und *Telehealth service terminals* als Prozess. Die Leistungserbringer senden Login-Anfragen an die Terminals und erhalten Antworten. Die Terminals und der *login process* tauschen Authentifizierungsanfrage und Ergebnis aus. Der Login-Prozess fragt den *Telehealth service Server* ab und erhält ein Abfrageergebnis. Dieser Server tauscht Daten mit den Record-Servern und dem Speicher *Database Files* aus. Die Flüsse sind keine Garantie für bereits vorhandene Zugriffskontrollen oder Verschlüsselung.

Im gegebenen Modell fließen Messungen direkt zwischen zwei Datenspeichern. Nach der Modellierungsregel des Microsoft-Moduls gehört ein Prozess zwischen kommunizierende Datenspeicher. Für eine überarbeitete Fassung würde ich deshalb einen Prozess für Erfassung oder Synchronisierung ergänzen, ohne ihn als bereits in der Angabe vorhanden darzustellen.

Messdaten und Logins über Geräte, Prozesse und Speicher verfolgen

(c)

Vertrauensgrenzen gehören an Übergänge zwischen verschiedenen Kontroll- oder Berechtigungsbereichen. Für dieses DFD schlage ich folgende Grenzen vor:

1. Zwischen Patient und App bzw. patientenseitiger Umgebung: vom externen Nutzer zur Anwendung.
2. Zwischen medizinischem Gerät und Kommunikationsgerät: unterschiedliche Geräte mit eigener Herkunft und Vertrauensannahmen.
3. Zwischen patientenseitiger Umgebung und Record-Servern: vom Heim-/Mobilbereich zum Backend.
4. Zwischen Healthcare providers und Terminals: vom externen Nutzer zum Dienst.
5. Zwischen Terminal und zentralem Login-Prozess, falls Terminal und Identitätsdienst getrennte Kontroll- oder Berechtigungsbereiche haben.
6. Zwischen Record-Servern und Telehealth-Server, falls unterschiedliche Betreiber, Dienstkonten oder Sicherheitszonen zuständig sind.

7. An Schnittstellen zwischen Backend und Datenbank, wenn die Datenhaltung eigene Zugriffsrechte und einen getrennten Sicherheitsbereich hat.

Die ersten Nutzer- und Backendübergänge ergeben sich aus den beschriebenen Rollen. Die weiteren Grenzen sind ausdrücklich Architekturannahmen und müssen mit der tatsächlichen Deployment- und Rechteverteilung abgeglichen werden. Nicht jeder Pfeil ist automatisch eine Vertrauensgrenze. An einem solchen Übergang sind Quelle, Authentifizierung, Autorisierung, Eingabeprüfung und angemessener Transport- bzw. Speicherschutz zu prüfen.

Grenzen nach Kontrolle und Berechtigungen setzen

Quellen

VO Systemsicherheit WS 2026/27: *SS_ WS2026_ 01.pdf*, Folien 1-4 bis 1-8 und 1-18 bis 1-27, `https://moodle.aau.at/mod/resource/view.php?id=1489056`. Die Antwort zu 1.2 verwendet die funktionalen Post-Entsprechungen der VO.

Microsoft Learn: *Create a threat model using data-flow diagram elements*, insbesondere die Einheiten zu Prozess, Datenspeicher, externer Entität, Datenfluss und Vertrauensgrenze, `https://learn.microsoft.com/en-us/training/modules/tm-create-a-threat-model-using-foundational-data-flow-diagram-elements/`. Die Definitionen der DFD-Elemente und die Regel für Verbindungen zwischen Datenspeichern stammen aus diesem Modul.

Die aktuellen Recherchequellen für Aufgabe 1.1 sind direkt bei den jeweiligen Antworten verlinkt. Es wurden keine persönlichen Erfahrungen oder tatsächlich erfolgten Sicherheitsvorfälle behauptet.